



# Vulnerability Scanning with Nessus

## A PRACTICAL GUIDE



<https://vimeo.com/hexsec>



### Q

## What is Nessus?

Nessus, developed by Tenable, is a powerful vulnerability scanner trusted by organizations worldwide to identify vulnerabilities in their IT infrastructure. It scans networks, servers, and applications to detect weaknesses that attackers could exploit. Nessus Professional is widely used in enterprise environments, while Nessus Essentials (formerly Nessus Home) is available for personal use, offering limited scanning capabilities for home networks.

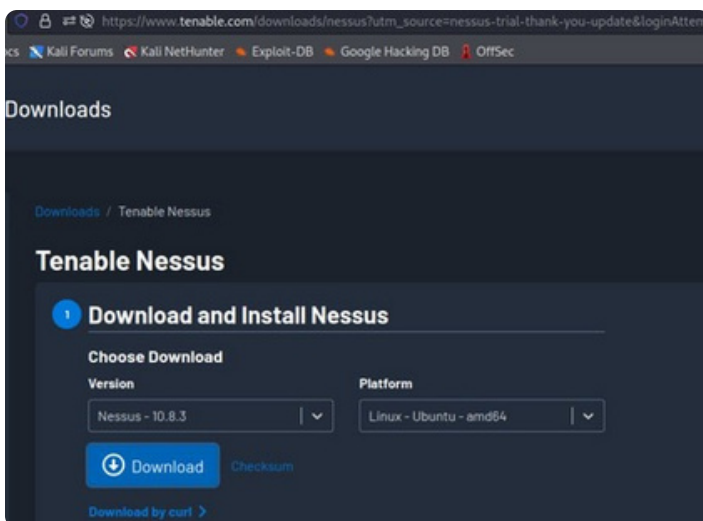
### Why Nessus?

The appeal of Nessus lies in its robust scanning engine, ease of use, and comprehensive coverage of vulnerabilities. It has one of the most extensive vulnerability databases, which is regularly updated to include the latest security issues. The scanner is capable of identifying misconfigurations, missing patches, default credentials, and more—making it an invaluable tool for security professionals.

## Setting Up Nessus

### Download and Install Nessus:

Visit the [Tenable website](https://www.tenable.com/downloads/nessus) to download the version suitable for your needs—Nessus Professional for business users or Nessus Essentials for home use.





## Vulnerability Scanning with Nessus A Practical Guide



```
root@kali: /home/kali/Downloads
File Actions Edit View Help
(root@kali)~[/home/kali/Downloads]
# ls
Nessus-10.8.3-ubuntu1604_amd64.deb
(root@kali)~[/home/kali/Downloads]
```

For installation, open the terminal and go to the download directory.

```
root@kali: /home/kali/Downloads
File Actions Edit View Help
(root@kali)~[/home/kali/Downloads]
# ls
Nessus-10.8.3-ubuntu1604_amd64.deb
(root@kali)~[/home/kali/Downloads]
# dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
(Reading database ... 298602 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.8.3) over (10.8.3) ...
Setting up nessus (10.8.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
```



For installation, use the following command :

```
# dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
```

Start the nessus service-

```
# service nessusd start
```

And for confirming whether the nessus service has been started or not, we can confirm it with:

```
# service nessusd status
```

```
- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://kali:8834/ to configure your scanner

(root@kali)-[/home/kali/Downloads]
# service nessusd start

(root@kali)-[/home/kali/Downloads]
# service nessusd status
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; disabled; vendor preset: disabled)
   Active: active (running) since Thu 2024-10-24 02:53:42 EDT; 3s ago
     Main PID: 2845316 (nessus-service)
        Tasks: 15 (limit: 11658)
       Memory: 82.7M
          CPU: 4.330s
      CGroup: /system.slice/nessusd.service
              └─2845316 /opt/nessus/sbin/nessus-service -q
                2845318 nessusd -q

Oct 24 02:53:42 kali systemd[1]: Started The Nessus Vulnerability Scanner.
Oct 24 02:53:42 kali nessus-service[2845318]: Cached 0 plugin libs in 0msec
Oct 24 02:53:42 kali nessus-service[2845318]: Cached 0 plugin libs in 0msec

(root@kali)-[/home/kali/Downloads]
#
```





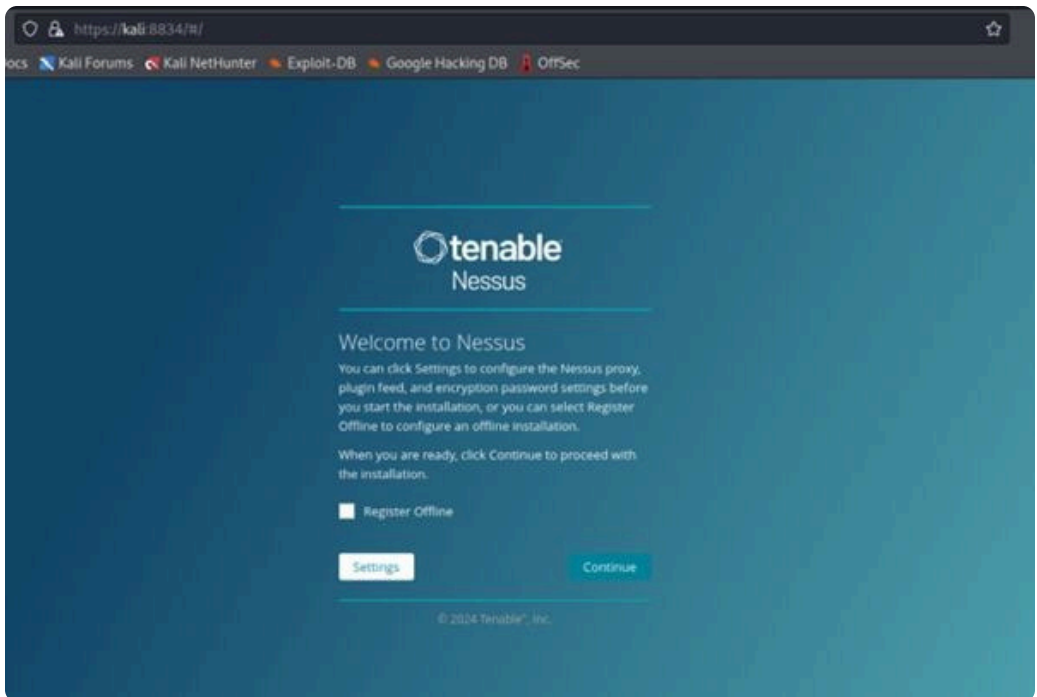
### 🔴 **Activate Your License:**

you'll need to activate your license. Nessus Essentials requires a free license key, while Nessus Professional comes with a paid license and a free trial of 7 days.

### **Configuration by using the command**

```
#service nessusd start
```

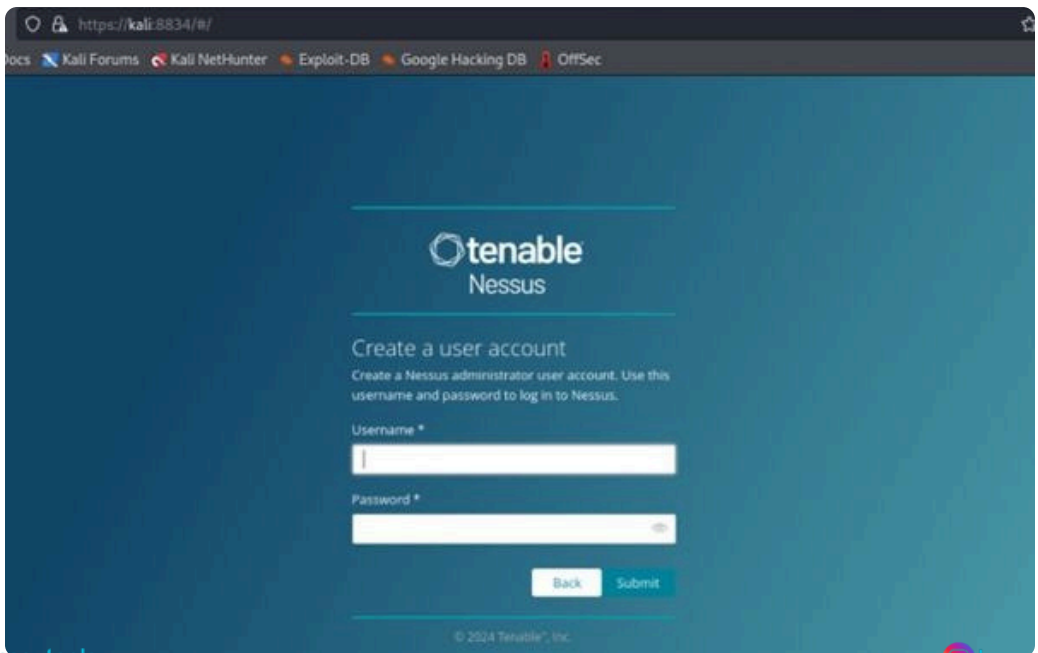
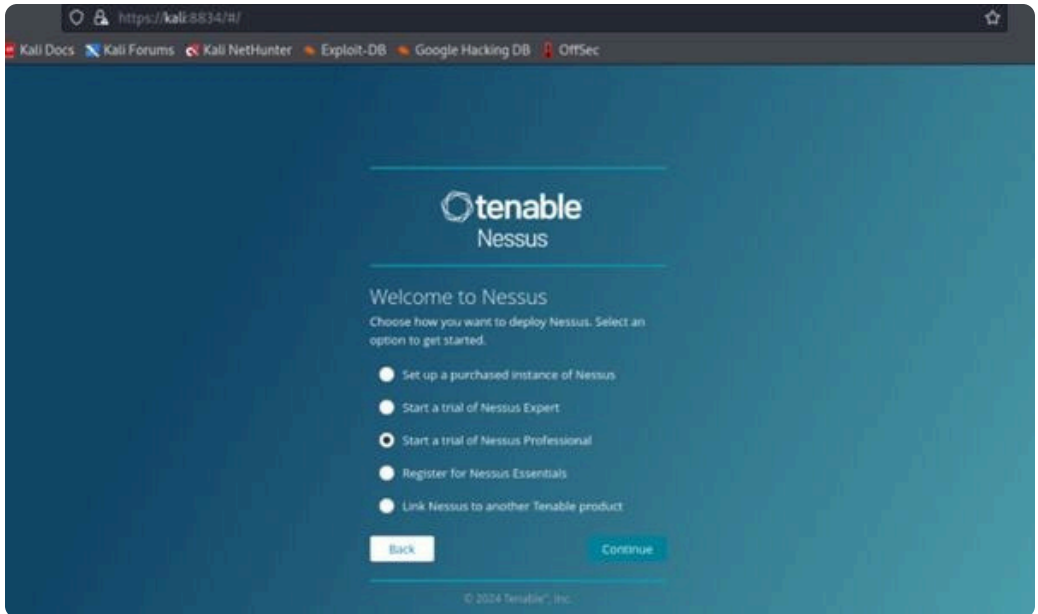
```
#service nessusd status
```



For setup, click on the checkbox register offline and then continue



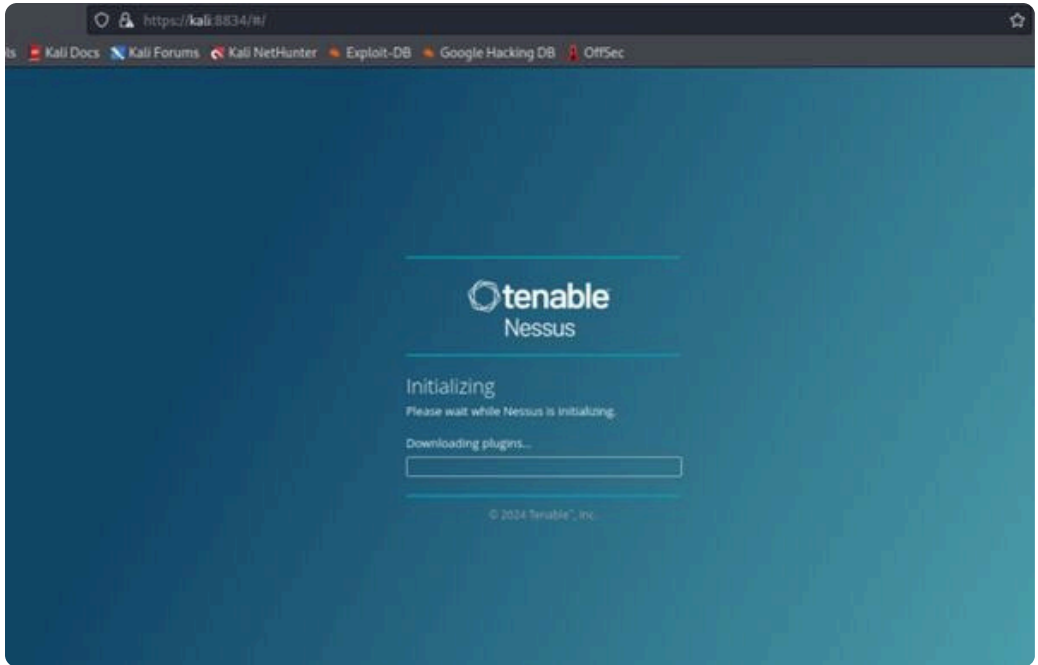
## Vulnerability Scanning with Nessus A Practical Guide





## Vulnerability Scanning with Nessus A Practical Guide

Create new user account by giving user id and password





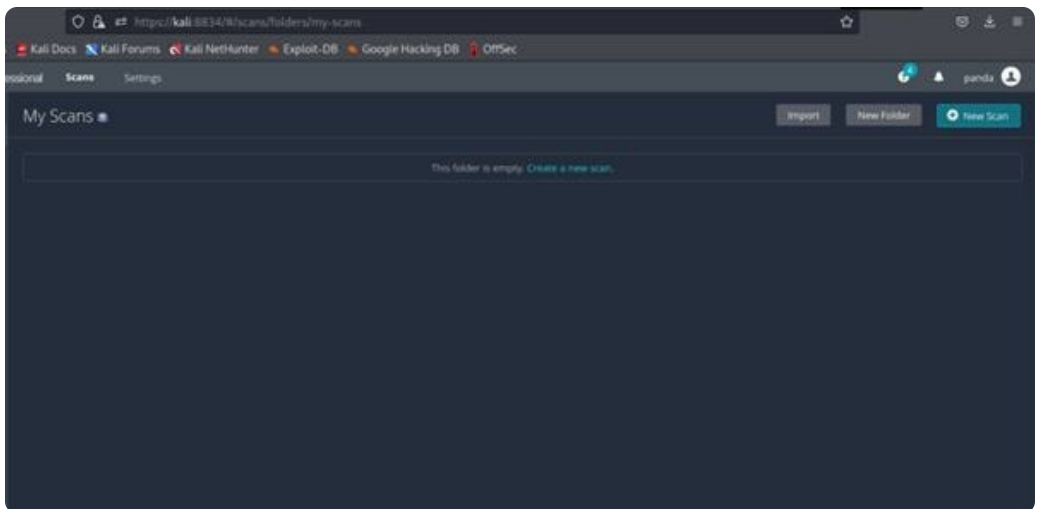
### 🔴 Set Up the Scanner:

Once Nessus is installed, you will be prompted to configure the scanner. You can choose from various scan types depending on your objectives (e.g., vulnerability assessment, compliance scans, or custom configurations).

### 1 Performing a Vulnerability Scan with Nessus

To start using Nessus Professional, you'll need to access the Nessus Professional dashboard through your web browser. By default, the Nessus Professional service runs on port 8834, so you can access it using the following URL:

<https://localhost:8834/>



Log in with your Nessus Professional credentials to access the dashboard.





### 2 Create a New Scan

Once you're logged in, click on the **"New Scan"** button to initiate a scan. Nessus Professional offers several templates to choose from, depending on your requirements:

- **Basic Network Scan:** A general vulnerability scan for networks.
- **Advanced Scan:** Provides detailed control over scan parameters.
- **Web Application Test:** Designed to identify vulnerabilities in web applications.

For our example, let's assume you want to perform a **Basic Network Scan**.

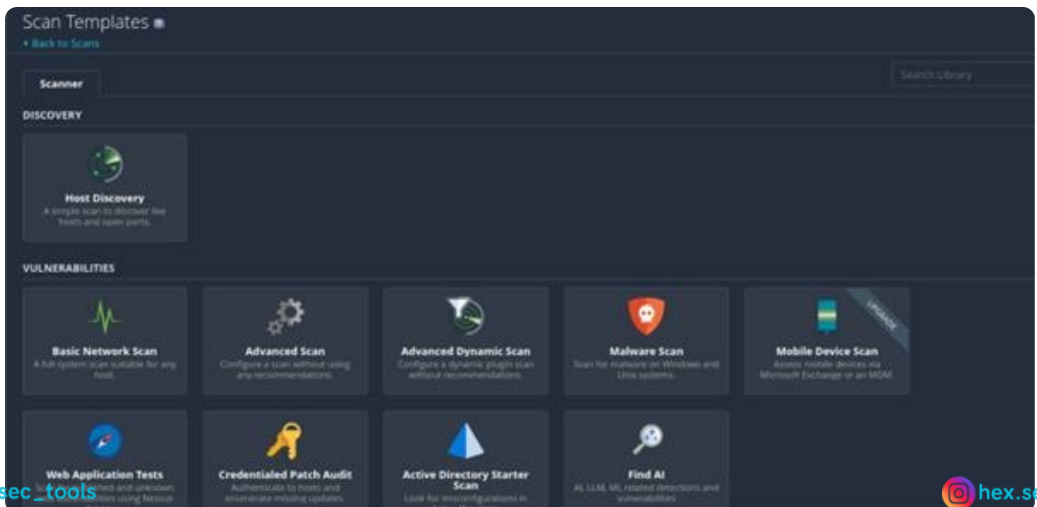
- Navigate to the **Scans** tab.
- Click on **New Scan**.
- Select **Basic Network Scan** from the list of available templates.

### 3 Configure Scan Settings

Once you select a scan template, you will need to configure the scan settings. This includes specifying your target, scan schedule, and any additional options like port ranges or scan timeouts.

**Steps:**

- **Name:** Provide a descriptive name for your scan (e.g., "Internal Network Scan").
- **Target:** Enter the target(s) for the scan.





- Range of IP Addresses

The screenshot shows the 'General Settings' tab in the Nessus interface. The left sidebar contains a navigation menu with categories: BASIC (General, Schedule, Notifications), DISCOVERY, ASSESSMENT, REPORT, and ADVANCED. The main content area is titled 'General Settings' and includes the following fields:

- Name:** Metasploitable 2
- Description:** Basic Network Scan
- Folder:** My Scans (dropdown menu)
- Targets:** 192.168.10.129
- Upload Targets:** Add File (button)
- Post-Processing:** (empty field)

Set up the scan with the target IP, specify the project name along with a detailed description, and ensure all output is saved to your "scan" folder.

- **Port Range:** If you want to scan a specific range of ports, configure the Port Range field. For example, to scan common ports: 1-1024, 8080, 8443

The screenshot shows the 'Ports' configuration tab in the Nessus interface. The left sidebar is the same as the previous screenshot. The main content area is titled 'Ports' and includes the following settings:

- Consider unscanned ports as closed:** ☒ When enabled, if a port is not scanned with a selected port scanner (for example, the port falls outside of the specified range), the scanner considers it closed.
- Port scan range:** 1-1024 (text input field). Below the field, it says: "Specifies the range of ports to be scanned."
- Local Port Enumerators:**
  - ☒ **SSH (nmapstat)**  
When enabled, the scanner uses nmapstat to check for open ports from the local machine. It relies on the nmapstat command being available via an SSH connection to the target. This scan is intended for Linux-based systems and requires authentication credentials.
  - ☒ **WMI (nmapstat)**  
When enabled, the scanner uses nmapstat to determine open ports while performing a WMI-based scan.
  - ☒ **SNMP**  
When enabled, if the appropriate credentials are provided by the user, the scanner can better test the remote host and produce more detailed audit results. For example, there are many Cisco router checks that determine the vulnerabilities present by examining the version of the returned SNMP string. This information is necessary for these audits.





- **Schedule:** If you want to automate the scan, you can set it to run periodically (e.g., daily or weekly) under the **Schedule** tab. **Daily Scan** (scheduled at 6:30 PM every day):

Settings | Credentials | Plugins

**BASIC**

- General
- Schedule**
- Notifications

**DISCOVERY**

**ASSESSMENT**

**REPORT**

**ADVANCED**

Enabled ☒

Frequency: Daily

Starts: 06:30 | 2024-10-24

Timezone: Asia/Kolkata

Repeat Every: Day

Summary: Daily at 6:30 AM, starting on Thursday, October 24th, 2024

Save | Cancel

- **Configure Authentication:** If your scan targets servers or devices requiring authentication, you can configure credentials such as SSH or SMB to gain deeper insights. Here's how to specify credentials in the scan configuration:  
SSH Authentication:





After configuring the scan settings, you're ready to launch the scan. Nessus Professional will immediately begin scanning the target network, and the time required will vary based on the network's size and complexity.

- Click Save to save the scan configuration.
- Click Launch to start the scan immediately.

### 5 Monitor the Scan Progress

Once the scan is launched, Nessus Professional will display the progress in real-time within the web interface. The status bar will show how far along the scan is, and once completed, the results will be available for review.

You can view the scan progress under the Scans tab, where you will see the percentage of the scan completed, the time elapsed, and the number of vulnerabilities detected so far.

The screenshot shows the Nessus Professional web interface. The 'Test' page is active, with the 'Vulnerabilities' tab selected. The main table lists vulnerabilities with columns for Severity, CVSS, VPR, EPSS, Name, Family, and Count. The 'Scan Details' sidebar on the right shows the policy, status, severity base, scanner, and start time. The 'Vulnerabilities' donut chart shows the distribution of vulnerability severity levels.

| Sev  | CVSS  | VPR | EPSS | Name                      | Family            | Count |
|------|-------|-----|------|---------------------------|-------------------|-------|
| Misc | —     | —   | —    | SSH (Multiple Issues)     | Misc.             | 6     |
| Misc | —     | —   | —    | Openbsd Openssh (...)     | Misc.             | 2     |
| LOW  | 2.1 * | —   | —    | ICMP Timestamp Request... | General           | 1     |
| Misc | —     | —   | —    | HTTP (Multiple Issues)    | Web Servers       | 3     |
| Misc | —     | —   | —    | Apache HTTP Server ...    | Web Servers       | 2     |
| Misc | —     | —   | —    | SSH (Multiple Issues)     | Service detection | 2     |
| Misc | —     | —   | —    | Nessus SYN scanner        | Port scanners     | 3     |
| Misc | —     | —   | —    | Service Detection         | Service detection | 3     |

**Scan Details**

- Policy: Basic Network Scan
- Status: Running
- Severity Base: CVSS v3.0
- Scanner: Local Scanner
- Start: Today at 6:40 AM

**Vulnerabilities**

- Critical
- High
- Medium
- Low
- Info





### 6 View and Analyze Scan Results

After the scan is completed, Nessus Professional will generate a comprehensive report outlining the vulnerabilities discovered. Each vulnerability will be categorized by its severity:

Download Scan Results in CSV Format:

**Generate Report**

Report Format: ☐ HTML ☒ PDF ☐ CSV

Select a Report Template:

☐ Hide system templates

SYSTEM

- Complete List of Vulnerabilities by Host
- Compliance
- Detailed Vulnerabilities By Host
- Detailed Vulnerabilities By Host with Compliance/Remediations
- Detailed Vulnerabilities By Plugin
- Detailed Vulnerabilities By Plugin with Compliance/Remediations**
- Remediations
- Summary of Exploitable Vulnerabilities
- Summary of Hosts with Vulnerabilities
- Summary of Known/Default Accounts
- Summary of Operating Systems
- Summary of Unsupported Software
- Summary of Vulnerabilities Older Than One Year
- Top 10 Vulnerabilities
- Vulnerability Operations

**Template Description:**  
This report presents detailed vulnerabilities by plugin, including the compliance and remediations checks.

**Filters Applied:**  
None

**Formatting Options:**  
☒ Include page breaks between vulnerability results

Generate Report Cancel Save as default

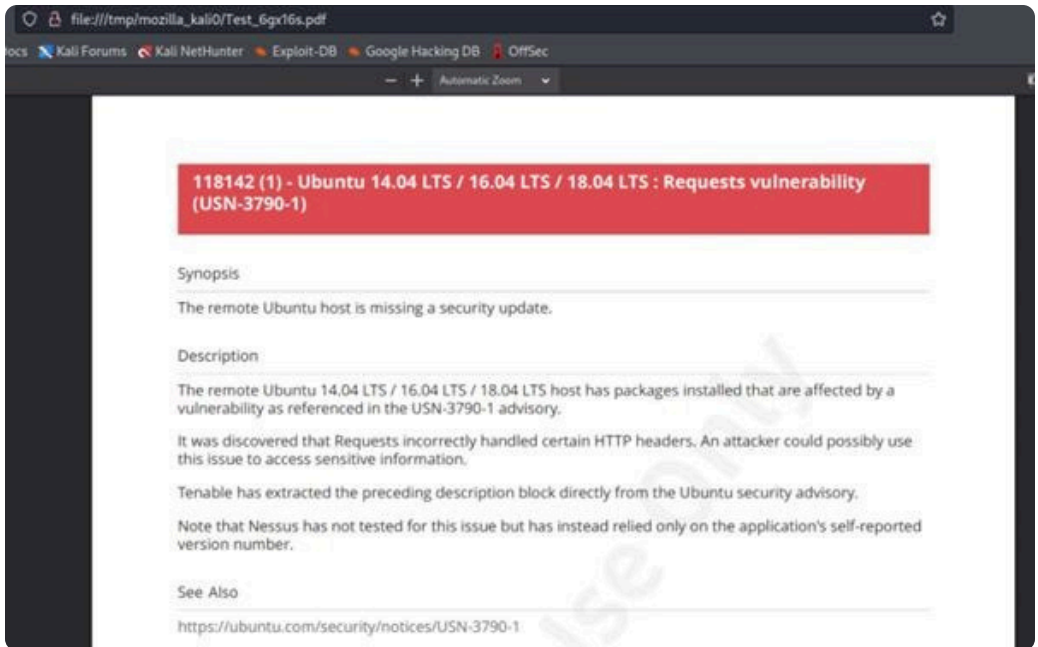




### 7 Exporting Results

You can export the scan results in different formats from the Nessus Professional web interface by following these steps:

- Open the scan results page.
- Click on Export.
- Choose the desired format (e.g., PDF, CSV, HTML).
- Save the file to your desired location.



### 8 Remediation and Continuous Scanning

Once vulnerabilities are identified, prioritize remediation based on their severity. After addressing the critical vulnerabilities, you can continuously monitor the environment by scheduling periodic scans.

Following these steps allows you to conduct an effective vulnerability scan using Nessus Professional, helping you secure your network against potential threats. Regular scans and diligent remediation are key components in maintaining a secure and resilient network environment.

